



Analista de Tecnologia da Informação / Área: Segurança da Informação

Prezado(a) Candidato(a),

Para assegurar a tranquilidade no ambiente de prova, a eficiência da fiscalização e a segurança no processo de avaliação, lembramos a indispensável obediência aos itens do Edital e aos que seguem:

01. Deixe sobre a carteira **APENAS caneta esferográfica de tubo transparente e documento de identidade**. Os demais pertences devem ser colocados embaixo da carteira, em saco entregue para tal fim. Os **celulares devem ser desligados**, antes de guardados. O candidato que for apanhado portando celular será automaticamente eliminado do certame.
02. Anote o seu número de inscrição e o número da sala no espaço reservado neste Caderno de Questões.
03. Antes de iniciar a resolução das 50 (cinquenta) questões, verifique se o Caderno está completo. Qualquer reclamação de defeito no Caderno deverá ser feita nos primeiros 30 (trinta) minutos após o início da prova.
04. Ao receber a Folha Resposta, confira os dados do cabeçalho. Havendo necessidade de correção de algum dado, chame o fiscal. Não use corretivo nem rasure a Folha Resposta.
05. A prova tem duração de **4 (quatro) horas** e o tempo mínimo de permanência em sala de prova é de **1 (uma) hora**.
06. É terminantemente proibida a cópia do gabarito, conforme subitem 13.16 do Edital.
07. A Folha Resposta do candidato será disponibilizada em sua área individual na data estabelecida no Cronograma de Atividades.
08. Ao terminar a prova, não esqueça de assinar a Ata de Aplicação e a Folha Resposta, no campo destinado à assinatura, e de entregar o Caderno de Questões e a Folha Resposta ao fiscal de sala.

Atenção! Os três últimos candidatos só poderão deixar a sala simultaneamente e após a assinatura da Ata de Aplicação.

Boa prova!

Fortaleza, 19 de janeiro de 2025.

Inscrição

Sala

01 Às vezes a gente não se dá conta, mas o mal-estar fica ali, triangulando entre cérebro,
02 estômago e boca: quer dizer que falamos errado? O idioma que aprendemos no berço não passa de
03 uma versão bastarda de certa língua para sempre estrangeira?

04 Me refiro ao estrago que a brigada de guardiães da "norma curta" faz à nossa autoestima
05 cultural e à qualidade do ensino de português em nossas escolas.

06 Para as patrulhas da norma-padrão, armadas de canetas vermelhas, o português brasileiro é um
07 coitado sem modos e cheio de vícios que não consegue largar, por mais cascudos que a gente
08 aplique em sua cabeça dura.

09 Usar "a gente" no lugar de "nós", como fiz na primeira linha da coluna e voltei a fazer na frase
10 anterior, é um dos sinais da suposta deterioração da língua que esses puristas extemporâneos
11 (século 21, oi!) gostam de apontar.

12 Na vida real, a gente adora falar "a gente". Sim, a gente briga, diz tanta coisa que não quer
13 dizer, mas "a gente" é uma coisa que a gente quase sempre quer dizer. Porque a gente não tem cara
14 de babaca — ou tem?

15 Verdade que, quando está escrevendo, a gente costuma se policiar. Ninguém quer perder ponto
16 na prova, caramba. Às vezes escapa um "a gente" escrito, mas não era pra escapar. A gente sabe
17 que no fundo está errado, que isso de "a gente" é um troço informal, tipo uma gíria, que não cabe
18 na norma culta, certo?

19 Errado. Ou melhor, a carga de informalidade de "a gente" é obviamente maior que a de "nós".
20 O que não faz sentido é tentar expulsar da norma culta tudo o que é informal, como se só coubesse
21 nela o livresco, o empertigado, o que fica distante da fala e se mete arranhando por ouvidos e
22 almas (...)

RODRIGUES, Sérgio. A gente é a língua que a gente fala. Folha de São Paulo. 16/03/2022. Disponível em:
<https://www1.folha.uol.com.br/colunas/sergio-rodrigues/2022/03/a-gente-e-a-lingua-que-a-gente-fala.shtml>

01. No primeiro parágrafo do texto, o termo “versão bastarda” (linha 03) refere-se ao:

- A) português culto.
- B) português europeu.
- C) português brasileiro.
- D) português não-padrão.

02. O uso do pronome destacado na frase: "**Me** refiro ao estrago que a brigada de guardiães da 'norma curta'" (linha 04) constitui:

- A) expressão da insubmissão do autor à rigidez dos puristas.
- B) inadequação gramatical injustificável em qualquer texto escrito.
- C) evidência de desconhecimento da norma gramatical estabelecida no Brasil.
- D) emprego condenável, mesmo no registro informal do português falado no Brasil.

03. A partir da leitura do texto, é correto afirmar que o termo “norma curta” (linha 04) é utilizado para:

- A) fazer alusão aos chamados vícios de linguagem.
- B) referir-se à norma utilizada por falantes escolarizados.
- C) criticar a utilização de termos informais na escrita padrão.
- D) ironizar a inflexibilidade de determinado padrão linguístico.

04. A partir da leitura do segundo parágrafo, podemos inferir que o autor:

- A) mostra que a deterioração da língua não é um fato evidente.
- B) explica seu gosto pelos usos informais da língua portuguesa.
- C) faz uma crítica à qualidade do ensino de língua portuguesa.
- D) defende a valorização da nossa cultura em detrimento de outras.

05. Como o uso do "a gente", comentado no trecho: "Usar 'a gente' no lugar de 'nós' (...) é um dos sinais da suposta deterioração da língua..." (linhas 09-10), constitui também sinal da suposta deterioração da língua empregar:
- A) a próclise em início de frase, como em "me refiro ao estrago..." (linha 04).
 - B) o pronome "esses" (linha 10) no lugar de "estes".
 - C) "porque", junto e sem acento em frase interrogativa, como ocorre na (linha 13).
 - D) a preposição "por" com verbo transitivo direto, como em "arranhando por ouvidos e almas" (linhas 21-22).
06. No trecho "A gente sabe que no fundo está errado, que **isso** de 'a gente' é um troço informal" (linhas 16-17), o termo em destaque tem a função de:
- A) retomar algo dito anteriormente.
 - B) dar ênfase à expressão "a gente".
 - C) substituir a primeira frase do período.
 - D) fazer referência ao contexto situacional.
07. No trecho "como se só coubesse nela o **livresco**" (linhas 20-21), o sufixo é utilizado em "livresco" para expressar o sentido de:
- A) interesse.
 - B) referência.
 - C) capacidade.
 - D) agentividade.
08. Assinale a alternativa em que a função sintática do termo destacado está indicada corretamente.
- A) "que não consegue largar" (linha 07) – sujeito.
 - B) "Às vezes escapa um 'a gente' escrito" (linha 16) – objeto direto.
 - C) "O que não faz sentido é tentar expulsar..." (linha 20) – objeto direto.
 - D) "como se só coubesse nela o livresco," (linhas 20-21) – sujeito.
09. Assinale a alternativa que reescreve corretamente, em registro formal escrito, o trecho do texto indicado.
- A) "a gente não se dá conta" (linha 01) / *nós não damos conta*.
 - B) "...que a gente aplique em sua cabeça dura" (linhas 07-08) / *que nós aplicamos em sua cabeça dura*.
 - C) "a gente quase sempre quer dizer" (linha 13) / *nós quase sempre queremos dizermos*.
 - D) "a gente costuma se policiar" (linha 15) / *nós costumamos policiar-nos*.
10. Ao defender o uso de "a gente", o autor utiliza recursos diversificados em sua argumentação. Assinale a alternativa que avalia corretamente os recursos persuasivos utilizados no texto.
- A) formas rejeitadas pela norma-padrão são utilizadas como estratégia para aproximar-se do leitor.
 - B) as construções metafóricas do texto visam deixar o leitor confuso com o fim de manipulá-lo.
 - C) termos bélicos como "brigada" e "armados" consiste em estratégia de ameaça aos puristas.
 - D) a interlocução direta com o leitor é um recurso usado para provocar constrangimento.

Prova 2 - Legislação

10 questões

01. Segundo o disposto na Lei nº 14.133/21, são modalidades de licitação:

- A) credenciamento, concurso, leilão.
- B) leilão, diálogo competitivo, pregão.
- C) concorrência, tomada de preços, convite.
- D) registro de preços, pré-qualificação, convite.

- 02.** Segundo a Lei nº 14.133/2021, que dispõe sobre diferentes modalidades de licitação, assinale a alternativa correta quanto às modalidades apresentadas e suas características.
- A) O pregão é a modalidade de licitação obrigatória para aquisição de bens e serviços comuns, cujo critério de julgamento poderá ser o de menor preço ou o de maior desconto.
 - B) O leilão exige fase de habilitação e registro cadastral prévio dos licitantes além de homologação quando concluídas as fases de lance, devendo ser efetivado o pagamento pelo licitante vencedor, na forma definida no edital.
 - C) O concurso é a modalidade de licitação obrigatória para contratações cujo objeto envolva inovação tecnológica ou técnica; impossibilidade de o órgão ou entidade ter sua necessidade satisfeita sem adaptação de soluções disponíveis no mercado; e, impossibilidade de as especificações técnicas serem definidas com precisão suficiente pela Administração.
 - D) A ata de registro de preços é a modalidade de licitação para contratação de bens e serviços especiais podendo ser utilizada para a realização de obras e serviços comuns e especiais de engenharia, cujo critério de julgamento poderá ser de técnica e preço.
- 03.** Nos termos do Art. 2º, parágrafo único, alínea c, do Estatuto da Universidade Federal do Ceará, aprovado pelo Conselho Nacional de Educação, conforme Parecer nº 62/99, da Câmara de Educação Superior e atualizado pelo Provimento no 01/CONSUNI, de 23 de agosto de 2023, assinale a alternativa que se refere à autonomia de gestão patrimonial e financeira da UFC.
- A) Firmar contratos, acordos, convênios e instrumentos similares.
 - B) Realizar os processos de escolha de reitor, vice-reitor, diretores e vice-diretores de unidades acadêmicas, de acordo com a legislação em vigor.
 - C) Aprovar e executar planos, programas e projetos de investimentos referentes a obras, serviços e aquisições em geral, bem como administrar rendimentos, conforme dispositivos institucionais.
 - D) Estabelecer critérios e normas a serem observados pelos corpos docente, discente, técnico-administrativo, bem como definir as sanções a que estão sujeitos os seus membros.
- 04.** O Brasil é organizado político-administrativamente pela União, Estados, Distrito Federal e Municípios. Todos com competências delimitadas, nos termos da Constituição Federal de 1988. É competência comum da União, dos Estados, Distrito Federal e Municípios o disposto somente na alternativa:
- A) explorar diretamente, ou mediante concessão, os serviços de gás canalizado.
 - B) proteger os documentos, as obras e outros bens de valor histórico, artístico e cultural, os monumentos, as paisagens naturais notáveis e os sítios arqueológicos.
 - C) organizar e prestar, diretamente ou sob regime de concessão ou permissão, os serviços públicos, incluído o de transporte coletivo, que tem caráter essencial.
 - D) instituir, mediante lei complementar, regiões metropolitanas, aglomerações urbanas e microrregiões, constituídas por agrupamentos de municípios limítrofes, para integrar a organização, o planejamento e a execução de funções públicas de interesse comum.
- 05.** Patrícia, servidora pública da UFC, recebeu de sua chefia imediata a determinação para aprimorar o sistema de proteção de dados pessoais sensíveis. Sem entender a determinação da sua chefia, resolveu consultar a Lei Geral de Proteção de Dados (LGPD), que considera como dado pessoal sensível:
- A) informação relacionada à pessoa natural identificada ou identificável.
 - B) conjunto estruturado de dados pessoais, estabelecido em um ou em vários locais, em suporte eletrônico ou físico.
 - C) dado relativo a titular que não possa ser identificado, considerando a utilização de meios técnicos razoáveis e disponíveis na ocasião de seu tratamento.
 - D) dado pessoal sobre origem racial ou étnica, convicção religiosa, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural.

06. Conforme preconiza o Decreto nº 1.171/94, que aprovou o Código de Ética Profissional do Servidor Público Civil do Poder Executivo Federal, a pena aplicável pela Comissão de Ética, que constará do respectivo parecer, assinado por todos os seus integrantes, com ciência do servidor público faltoso, é:
- A) censura.
 - B) exoneração.
 - C) advertência.
 - D) suspensão com perda de vencimentos.
07. Segundo o disposto no Estatuto da UFC, assinale a alternativa correta no que concerne somente às competências do Conselho Universitário.
- A) Aprovar os planos de cursos de graduação e de pós-graduação.
 - B) Superintender e coordenar, em nível superior ao da Administração Acadêmica, as atividades universitárias de ensino, pesquisa e extensão.
 - C) Homologar as decisões dos Conselhos de Centro e dos Conselhos Departamentais relativas à transferência, para a Universidade Federal do Ceará, de professores pertencentes a outras instituições de ensino superior mantidas pela União, exigindo-se votação de 2/3 (dois terços) quando se tratar de professor titular.
 - D) Fixar normas complementares às do Regimento Geral sobre o processo seletivo, currículos e programas, matrícula, transferência, avaliação do rendimento escolar, revalidação de diplomas estrangeiros, aproveitamento de estudos, regime de pesquisa e extensão, além de outras que se incluam no âmbito de sua competência.
08. Para fins da aplicação do disposto no Art. 2º da Lei nº 14.681/2023, pode-se afirmar que:
- A) o bem-estar no trabalho é o estabelecimento de relações interpessoais no trabalho com foco na mediação e na harmonia entre o profissional e seus pares e entre o profissional e seus superiores e subordinados.
 - B) a proposta de saúde integral objetiva estabelecimento de plano organizacional que desenvolva ações para educação e para inclusão social dos trabalhadores com deficiência e que lhes garanta as condições de trabalho essenciais às necessidades laborais.
 - C) a Política de Bem-Estar e Qualidade de Vida no Trabalho será realizada para a promoção dos indicadores de gestão e instrumentos de avaliação das metas pactuadas.
 - D) a qualidade de vida no trabalho é conjunto de normas, diretrizes e práticas que integram as condições, a organização, os processos de trabalho, as práticas de gestão e as relações socioprofissionais, com a finalidade de alinhar as necessidades e o bem-estar dos servidores à missão institucional.
09. Samantha é servidora estável ocupante de cargo de nível médio do Tribunal Regional Eleitoral do Ceará (TRE) com jornada diária de 6 (seis) horas e 30 (trinta) horas semanais. Fez concurso para docente na Universidade Federal do Ceará com jornada de 20 (vinte) horas semanais. Sobre a situação, pode-se afirmar que:
- A) a acumulação dos cargos é lícita, desde que haja compatibilidade de horário.
 - B) a acumulação é ilícita e, provada a má-fé da servidora, será aplicada a pena de demissão.
 - C) a acumulação dos cargos é ilícita e, constatada, será oportunizado à servidora, no prazo improrrogável de trinta dias, a opção por um dos cargos, sob pena de instauração de processo administrativo disciplinar.
 - D) a servidora, para que haja a continuidade do tempo de serviço público, deverá tomar posse no cargo de docente cumulativamente com o cargo de nível médio e só após poderá pedir exoneração deste último.
10. Segundo o disposto na Lei nº 8.112/90, são formas simultaneamente de provimento e de vacância de cargo público:
- A) promoção e readaptação.
 - B) ascensão e transferência.
 - C) nomeação e aposentadoria.
 - D) nomeação e posse em outro cargo inacumulável.

- 01.** No Brasil, a Lei Nº 13.709, de 14 de agosto de 2018, conhecida como a Lei Geral de Proteção de Dados Pessoais (LGPD), dispõe sobre o tratamento de dados pessoais, inclusive nos meios digitais, por pessoa natural, ou por pessoa jurídica de direito público ou privado, com o objetivo de proteger os direitos fundamentais de liberdade e de privacidade e o livre desenvolvimento da personalidade da pessoa natural. Para os fins desta Lei, são considerados agentes de tratamento:
- A) o titular e o operador.
 - B) o encarregado e o titular.
 - C) o controlador e o operador.
 - D) o controlador e o encarregado.
- 02.** A Lei Geral de Proteção de Dados Pessoais (LGPD) aplica-se a qualquer operação de tratamento realizada por pessoa natural ou por pessoa jurídica de direito público ou privado, independentemente do meio, do país de sua sede ou do país onde estejam localizados os dados. Assinale a alternativa que apresenta uma exceção à aplicação da LGPD.
- A) A operação de tratamento seja realizada no território nacional.
 - B) Os dados pessoais objeto do tratamento tenham sido coletados no território nacional.
 - C) O tratamento de dados pessoais seja realizado por pessoa natural para fins exclusivamente particulares e não econômicos.
 - D) A atividade de tratamento tenha por objetivo a oferta ou o fornecimento de bens ou serviços ou o tratamento de dados de indivíduos localizados no território nacional.
- 03.** Um importante produto da criptografia de chave pública é a assinatura digital ou assinatura eletrônica. No Brasil, as assinaturas eletrônicas são válidas e reconhecidas legalmente através da Infraestrutura de Chaves Públicas Brasileira (ICP-Brasil). O uso de assinatura digital permite a garantia das seguintes propriedades de segurança da informação:
- A) autenticidade e integridade.
 - B) autenticidade e disponibilidade.
 - C) confidencialidade e integridade.
 - D) disponibilidade e confidencialidade.
- 04.** O sigilo de uma informação a um terceiro pode ser alcançado através da aplicação de um dos seguintes métodos: pela ocultação de sua existência, disfarçando a informação em outra mensagem; ou pela aplicação de uma série de transformações sobre a informação sigilosa, tornando-a ininteligível. Um grau ainda maior de sigilo pode ser alcançado ao combinar os dois métodos. Os métodos mencionados são, respectivamente:
- A) assinatura digital e esteganografia.
 - B) esteganografia e criptografia.
 - C) entropia e assinatura digital.
 - D) criptografia e entropia.
- 05.** Ferramentas como OpenVAS e Nessus auxiliam os analistas no processo de identificação, classificação e monitoramento de vulnerabilidades em ativos organizacionais. A fim de obter um resultado com uma menor incidência de falsos positivos sob uma faixa de endereços IP de servidores, deve-se configurar uma varredura do tipo:
- A) autenticada e ativa.
 - B) autenticada e passiva.
 - C) não-autenticada e ativa.
 - D) não-autenticada e passiva.

06. Em busca de alcançar uma postura de segurança bem-sucedida, as organizações devem realizar, periodicamente, testes de segurança em seus ativos. Sejam estes sob a perspectiva da rede interna, rede externa, dispositivos, sistemas ou aplicativos. Assinale a alternativa que apresenta uma afirmação sobre testes de invasão, ou *pentests*.
- A) Permitem a identificação de todas as vulnerabilidades de uma aplicação.
 - B) Permitem a correlação de eventos nos logs dos servidores de aplicação testados.
 - C) Verificam a presença de vulnerabilidades apenas pelo cruzamento de informações previamente existentes em dicionários de vulnerabilidades como o Common Vulnerabilities and Exposures (CVE).
 - D) Podem ser utilizados para convencer os gestores, e demais tomadores de decisões, a respeito dos riscos de segurança da organização frente a ataques reais.
07. O processo de identificação e tratamento de problemas de segurança no projeto de aplicações ou sistemas, ou seja, antes que o código seja desenvolvido, é conhecido como:
- A) teste de invasão.
 - B) revisão de código.
 - C) modelagem de ameaças.
 - D) gerenciamento de vulnerabilidades.
08. Um "Computer Security Incident Response Team (CSIRT)", ou Grupo de Resposta a Incidentes de Segurança, é um grupo responsável por receber, analisar e responder a notificações e atividades relacionadas a incidentes de segurança em computadores. Uma estratégia que pode ser utilizada por CSIRTs na avaliação e desenvolvimento de seus procedimentos e uso de ferramentas é a realização de exercícios de simulação do tipo Red Team e Blue Team. Assinale a alternativa que resume as ações de cada um dessas equipes durante esse tipo de exercício.
- A) Os membros do Red Team coordenam as ações; enquanto os membros do Blue Team avaliam as decisões tomadas durante o exercício.
 - B) Os membros do Blue Team coordenam as ações, enquanto os membros do Red Team avaliam as decisões tomadas durante o exercício.
 - C) Os membros do Blue Team utilizam táticas e técnicas de invasão; enquanto os membros do Red Team utilizam táticas e técnicas de resposta e recuperação.
 - D) Os membros do Red Team utilizam táticas e técnicas de invasão; enquanto os membros do Blue Team utilizam táticas e técnicas de resposta e recuperação.
09. "Um incidente de segurança em computadores pode ser definido como uma atividade nas máquinas ou na rede que possa ameaçar a segurança dos sistemas computacionais."
- (Fonte: https://cert.br/certcc/csirts/csirt_faq-br.html).
- Um indício de que um ativo ou rede foi atacado com sucesso ou continua sendo atacado é chamado de:
- A) payload.
 - B) vetor de ataque.
 - C) vulnerabilidade.
 - D) indicador de comprometimento.
10. De acordo com o Glossário de Segurança da Informação, do Gabinete de Segurança Institucional da Presidência da República, a Negação de Serviço Distribuída (DDoS) é "uma atividade maliciosa, coordenada e distribuída, em que um conjunto de computadores ou de dispositivos móveis é utilizado para tirar de operação um serviço, um computador ou uma rede conectada à Internet". Marque a alternativa que apresenta medidas que podem ser utilizadas para mitigar ataques de DDos.
- A) Balanceadores de carga e Antispam.
 - B) Balanceadores de carga e VLANs.
 - C) Antispam e VPNs.
 - D) UPS e VLANs.

11. Após sofrer uma série de ataques cibernéticos no último ano, uma empresa do setor educacional contratou uma auditoria de segurança da informação. Dentre as descobertas, o relatório de auditoria apontou que a elaboração e a aprovação de mecanismos de segurança nesta empresa estavam sendo executadas por uma única pessoa. De acordo com a ABNT NBR ISO/IEC 27002:2022, qual dos itens a seguir apresenta um controle capaz de mitigar os riscos inerentes à vulnerabilidade destacada?
- A) Codificação segura.
 - B) Coleta de evidências.
 - C) Segregação de funções.
 - D) Contato com autoridades.
12. Para a ABNT NBR ISO/IEC 27005:2023, “os riscos de segurança da informação podem estar associados ao potencial de que as ameaças explorem vulnerabilidades de um ativo de informação ou grupo de ativos de informação e, assim, causem danos a uma organização.” Ao optar por não coletar certas informações de indivíduos para que não seja necessário gerenciá-las, armazená-las e transmiti-las em seus sistemas de informação, qual opção de tratamento de risco está sendo selecionada pela organização?
- A) Evitar riscos.
 - B) Retenção de riscos.
 - C) Modificação de riscos.
 - D) Compartilhamento de riscos.
13. Analise o seguinte cenário: após ser infectado por um tipo de software malicioso (malware), um dispositivo foi utilizado como fonte para a infecção de novas máquinas na rede interna de uma organização. Os hospedeiros infectados foram identificados e analisados, sendo encontrados malwares que capturavam tudo o que era digitado por usuários, além de um processo que permitia o acesso ao atacante para a extração dessas informações.
- Assinale a alternativa que apresenta a classificação dos malwares relatados no cenário acima.
- A) Rootkit; Backdoor e Bot.
 - B) Worm; Keylogger e Backdoor.
 - C) Worm; Ransomware e Backdoor.
 - D) Cavalo de Troia; Rootkit e Vírus.
14. Ettercap é uma ferramenta para análise de redes e hospedeiros que permite o sniffing de conexões ativas, a filtragem de conteúdo em tempo real, a dissecação ativa e passiva de protocolos etc. Utilizando o Ettercap, um atacante pode transmitir pacotes ARP não solicitados para alvos em uma rede local. Como o protocolo ARP não possui mecanismos de segurança, os dispositivos receptores confiam nessa comunicação e atualizam suas tabelas ARP com o endereço falsificado. Assinale o item que apresenta, respectivamente, o nome da técnica descrita e que tipo de ataque pode ser realizado pelo atacante utilizando-a.
- A) MAC flooding e ataque de MITM.
 - B) ARP poisoning e ataque de MITM.
 - C) MAC flooding e ataque de Evil Twin.
 - D) ARP poisoning e ataque de força bruta.
15. Uma rede virtual privada (VPN) estabelece um túnel seguro entre origem e destino, mesmo quando os pacotes passam pelos roteadores dos provedores de Internet. Assinale o item que apresenta o protocolo comumente utilizado em conjunto com o IPSec para fornecer um cliente VPN de acesso remoto com autenticação de usuário.
- A) Layer 2 Tunneling Protocol (L2TP).
 - B) Point-to-Point Tunneling Protocol (PPTP).
 - C) Secure Sockets Tunneling Protocol (SSTP).
 - D) Remote Authentication Dial-in User Service (RADIUS).

16. “Detran alerta para golpes por mensagens SMS: Unidades dos departamentos estaduais de Trânsito (Detrans) em todo o Brasil têm chamado a atenção para tentativas de golpe envolvendo mensagens de texto. Essas mensagens direcionam para sites falsos que solicitam dados pessoais, alegando suspensão ou cassação da Carteira Nacional de Habilitação (CNH).”

(Fonte: <https://www.opovo.com.br/noticias/brasil/2024/11/19/detran-alerta-para-golpes-por-mensagens-sms.html>).

Ataques de engenharia social utilizando esse vetor de ataque são conhecidos como:

- A) vishing.
 - B) whaling.
 - C) phishing.
 - D) smishing.
17. Ao criar sua equipe de resposta a incidentes (CSIRT), a organização deverá definir seus serviços considerando as estruturas e modelos adequados para fornecê-los. Essas definições serão implementadas através de um plano, políticas e procedimentos de resposta a incidentes, garantindo que a equipe tenha a autonomia necessária para agir de forma eficaz, eficiente e consistente no ambiente organizacional. Considerando as fases do processo de tratamento de incidentes, assinale o item que apresenta a ordem correta para estas fases.
- A) I - Preparação; II - Detecção e Análise; III - Contenção, Erradicação e Recuperação; IV - Emissão de relatórios e Retenção de evidências.
 - B) I - Preparação; II - Detecção e Análise; III - Emissão de relatórios e Retenção de evidências; IV - Contenção, Erradicação e Recuperação.
 - C) I - Detecção e Análise; II - Emissão de relatórios e Retenção de evidências; III - Preparação; IV - Contenção, Erradicação e Recuperação.
 - D) I - Detecção e Análise; II - Preparação; III - Contenção, Erradicação e Recuperação; IV - Emissão de relatórios e Retenção de evidências.
18. “O Open Worldwide Application Security Project (OWASP) é uma fundação sem fins lucrativos que trabalha para melhorar a segurança do software. [...] Somos uma comunidade aberta dedicada a permitir que organizações concebam, desenvolvam, adquiram, operem e mantenham aplicativos confiáveis. Todos os nossos projetos, ferramentas, documentos, fóruns e capítulos são gratuitos e abertos a qualquer pessoa interessada em melhorar a segurança de aplicativos”.

(Fonte: <https://owasp.org/about/>).

Assinale a alternativa que descreve o OWASP Top Ten.

- A) É uma lista, desenvolvida pela comunidade, de fraquezas comumente encontradas em software e hardware.
 - B) Sua missão é identificar, definir e catalogar vulnerabilidades de segurança cibernética divulgadas publicamente.
 - C) É uma base de conhecimento globalmente acessível sobre táticas e técnicas adversárias baseadas em observações do mundo real.
 - D) Representa um amplo consenso sobre os riscos de segurança mais críticos e um padrão de conscientização para desenvolvedores e segurança de aplicações Web.
19. Descendo para a terceira posição do OWASP Top Ten:2021, a categoria de Injeção inclui Enumerações de Fraquezas Comuns (Common Weaknesses Enumeration - CWE) notáveis como: CWE-79: Cross-site Scripting; CWE-89: SQL Injection e CWE-73: External Control of File Name or Path. Assinale a alternativa que NÃO apresenta uma forma de mitigar vulnerabilidades nessa categoria.
- A) Usar validação de entrada positiva do lado do servidor.
 - B) Para quaisquer consultas dinâmicas residuais, utilizar a sintaxe de escape de caracteres especiais específica para o interpretador utilizado.
 - C) Desabilitar a listagem de diretórios do servidor web e garantir que metadados de arquivos (por exemplo, .git) e arquivos de backup não estejam presentes nas raízes da web.
 - D) Utilizar uma API segura, que evite usar o interpretador completamente, forneça uma interface parametrizada ou migre para Ferramentas de Mapeamento Objeto-Relacional (ORMs).

20. De acordo com o OWASP Top Ten:2021, falhas que ocorrem sempre que uma aplicação web realiza a busca de um recurso remoto sem validar a URL fornecida pelo usuário, permitindo que um invasor possa forçar a aplicação a enviar uma solicitação elaborada para um destino inesperado, ainda que protegido por um firewall, VPN ou outro tipo de lista de controle de acesso à rede (ACL). Assinale o item que apresenta a categoria do OWASP Top Ten descrita no enunciado.
- A) Injeção.
 - B) Design inseguro.
 - C) Quebra de controle de acesso.
 - D) Falsificação de solicitação do lado do servidor.
21. De acordo com a ABNT NBR ISO/IEC 27002:2022, a respeito do uso aceitável de informações e outros ativos associados, NÃO convém que uma política específica por tema declare:
- A) comportamentos esperados e inaceitáveis dos indivíduos do ponto de vista de segurança da informação.
 - B) procedimentos estabelecidos para verificar a identidade de um usuário antes de fornecer informações novas, de substituição ou de autenticação temporária.
 - C) o uso permitido e proibido de informações e outros ativos associados.
 - D) atividades de monitoramento que estão sendo realizadas pela organização.
22. A Lei Nº 12.965, de 23 de abril de 2014, também conhecida como Marco Civil da Internet (MCI), estabelece princípios, garantias, direitos e deveres para o uso da Internet no Brasil. Quanto aos registros tratados pelo MCI, assinale a alternativa correta.
- A) Na provisão de conexão à internet, cabe ao administrador de sistema autônomo respectivo o dever de manter os registros de conexão, sob sigilo, em ambiente controlado e de segurança, pelo prazo de 1 (um) ano, nos termos do regulamento.
 - B) Na provisão de aplicações de internet, cabe ao administrador de sistema autônomo respectivo o dever de manter os registros de conexão, sob sigilo, em ambiente controlado e de segurança, pelo prazo de 6 (seis) meses, nos termos do regulamento.
 - C) O provedor de aplicações de internet constituído na forma de pessoa jurídica e que exerça essa atividade de forma organizada, profissionalmente e com fins econômicos deverá manter os respectivos registros de acesso a aplicações de internet, sob sigilo, em ambiente controlado e de segurança, pelo prazo de 1 (um) ano, nos termos do regulamento.
 - D) O provedor de conexão à internet constituído na forma de pessoa jurídica e que exerça essa atividade de forma organizada, profissionalmente e com fins econômicos deverá manter os respectivos registros de acesso a aplicações de internet, sob sigilo, em ambiente controlado e de segurança, pelo prazo de 6 (seis) meses, nos termos do regulamento.
23. Uma empresa de médio porte recentemente designou um gestor para a área de segurança da informação, entretanto as práticas de segurança ainda são implementadas de maneira reativa e de forma descentralizada pelas demais equipes de Tecnologia da Informação. Marque a alternativa que apresenta, respectivamente, os níveis de rigor das práticas de governança de risco de segurança cibernética e de gerenciamento de risco de segurança cibernética desta empresa de acordo com a Estrutura de Segurança Cibernética 2.0, do Instituto Nacional de Padrões e Tecnologias (NIST CSF 2.0).
- A) Parcial e Adaptativo.
 - B) Adaptativo e Repetível.
 - C) Parcial e Risco Informado.
 - D) Risco Informado e Repetível.
24. Uma equipe de tratamento de incidentes está analisando uma campanha de phishing através da qual um atacante utiliza uma página falsa com várias camadas transparentes ou opacas para induzir suas vítimas a interagir com uma página Web diferente daquela que eles acreditam estar interagindo. Marque a alternativa que identifica esse tipo de ataque e uma possível técnica de mitigação para ele.
- A) Clickjacking. X-Frame-Options: SameSite.
 - B) Clickjacking. X-Frame-Options: DENY.
 - C) XSS. X-Content-Type-Options: nosniff.
 - D) Injeção SQL. Validação de entradas.

- www.pciconcursos.com.br